ESCUELA MILITAR DE INGENIERÍA
“Mcal. ANTONIO JOSE DE SUCRE”
BOLIVIA

TRABAJO EXAMEN OPTATIVO

Vulnerabilidad de Divulgación de Cadena de Comunidad por Defecto (CVE-1999-0517) – Según la Prueba A05:2021 de Credenciales por defecto de OWASP (OTG-AUTHN-002)

EST. ZALLES MERINO IZAI ALEJANDRO

LA PAZ, 2025

ESCUELA MILITAR DE INGENIERÍA
“Mcal. ANTONIO JOSE DE SUCRE”
BOLIVIA

TRABAJO EXAMEN OPTATIVO

Vulnerabilidad de Divulgación de Cadena de Comunidad por Defecto (CVE-1999-0517) – Según la Prueba A05:2021 de Credenciales por defecto de OWASP (OTG-AUTHN-002)

EST. ZALLES MERINO IZAI ALEJANDRO

Modalidad: Examen Optativo

DOCENTE: ING. PATRICIA LOPEZ AVENDAÑO

LA PAZ, 2025

ÍNDICE

EMI
ESCUELA MILITAR DE INGENIERÍA
"Mcal. Antonio José de Sucre"
Prestigio, Disciplina y Mejores Oportunidades

ÍNDICE

1 INTRODUCCIÓN.....1

1.1 Panorama general de SNMP y la vulnerabilidad CVE-1999-0517.....1

1.2 Normas ISO/IEC relevantes para la vulnerabilidad SNMP por defecto…….3

1.3 Relevancia actual de la vulnerabilidad dentro de seguridad de sistemas..4

1.4 Objetivos de la prueba.....5

1.4.1 Objetivo General.....5

1.4.2 Objetivos específicos.....6

2 METODOLOGÍA.....7

2.1 Descripción del entorno de prueba.....7

2.1.1 Topología de la red de pruebas.....7

2.1.2 Equipo anfitrión (Kali Linux 2025.1).....8

2.1.3 Equipo virtual objetivo (Ubuntu 24.04.2 LTS).....10

2.2 Herramientas utilizadas.....13

2.3 Pasos seguidos para realizar la prueba.....14

3 RESULTADOS.....23

3.1 Descripción de los resultados obtenidos.....23

3.1.1 Análisis del Puerto SNMP UDP 161.....23

3.1.2 Fingerprinting del servicio SNMP.....23

3.1.3 Comprobación de acceso no autenticado usando la comunidad "public". 24

3.1.4 Extracción de la información del dispositivo.....24

3.2 Evidencia de la vulnerabilidades.....24

3.3 Análisis del impacto potencial de la vulnerabilidad en un sistema real…28

4 ANÁLISIS Y DISCUSIÓN.....30

4.1 Causas de la vulnerabilidad y comparación con vulnerabilidades similares.....30

4.2 Evaluación del cumplimiento normativo.....31

4.3 Limitaciones de la prueba realizada.....32

4.4 Posibles variaciones o mejoras en la prueba.....32

5 RECOMENDACIONES DE MITIGACIÓN.....34

5.1 Medidas específicas para corregir la vulnerabilidad.....34

5.2 Buenas prácticas de seguridad para prevenir futuras ocurrencias.....34

5.3 Consideraciones sobre la implementación de las mitigaciones.....35

6 CONCLUSIONES.....37
6.1 Resumen de los hallazgos de la prueba.....37
6.2 Reflexiones finales sobre la importancia de la prueba realizada.....37
7 REFERENCIAS.....38

FIGURAS

FIGURA 1: Diagrama de interpretación de OID.....2
FIGURA 2: Topología del laboratorio representada con MIRO.....8
FIGURA 3: Información del sistema mostrada por Neofetch en Kali Linux.....9
FIGURA 4: Información del sistema mostrada por Neofetch en Ubuntu Linux.....10
FIGURA 5: Contenido del archivo snmpd.conf mostrado por cat en Ubuntu Linux….11
FIGURA 6: Estado del servicio SNMP mostrado por systemctl en Ubuntu Linux.....12
FIGURA 7: Puerto que el sistema se encuentra escuchando mostrado por ss y filtrado por grep en Ubuntu Linux.....13
FIGURA 8: Escaneo de puertos mostrado por nmap en Kali Linux.....15
FIGURA 9: Consulta de MIB del dispositivo objetivo por nmap en Kali Linux.....16
FIGURA 10: Verificación del funcionamiento de “public” sin autenticación del dispositivo objetivo por snmpwalk en Kali Linux.....17
FIGURA 11: Prueba de cadenas predeterminadas variadas mostrada y realizada por snmpwalk en Kali Linux.....18
FIGURA 12: Extracción de los objetos de MIB-II system del dispositivo objetivo por snmpwalk en Kali Linux.....19
FIGURA 13: Enumeración de interfaces de red del dispositivo objetivo por snmpwalk en Kali Linux.....20
FIGURA 14: Listado de rutas IP del dispositivo objetivo por snmpwalk en Kali Linux. 21
FIGURA 15: Extracción de tabla ARP del dispositivo objetivo por snmpwalk en Kali Linux.....22
FIGURA 16: Puerto UDP 161 abierto mostrado por Nmap en Kali Linux.....25
FIGURA 17: Respuesta exitosa a snmpwalk mostrando el sysDescr en Kali Linux…26
FIGURA 18: Extracción de objetos system desde el MIB-II mostrado por snmpwalk en Kali Linux.....27
FIGURA 19: Tabla ARP extraída y mostrada por snmpwalk en Kali Linux.....28

INTRODUCCIÓN

EMI
ESCUELA MILITAR DE INGENIERÍA
"Mcal. Antonio José de Sucre"
Prestigio, Disciplina y Mejores Oportunidades

1 INTRODUCCIÓN

1.1 Panorama general de SNMP y la vulnerabilidad CVE-1999-0517

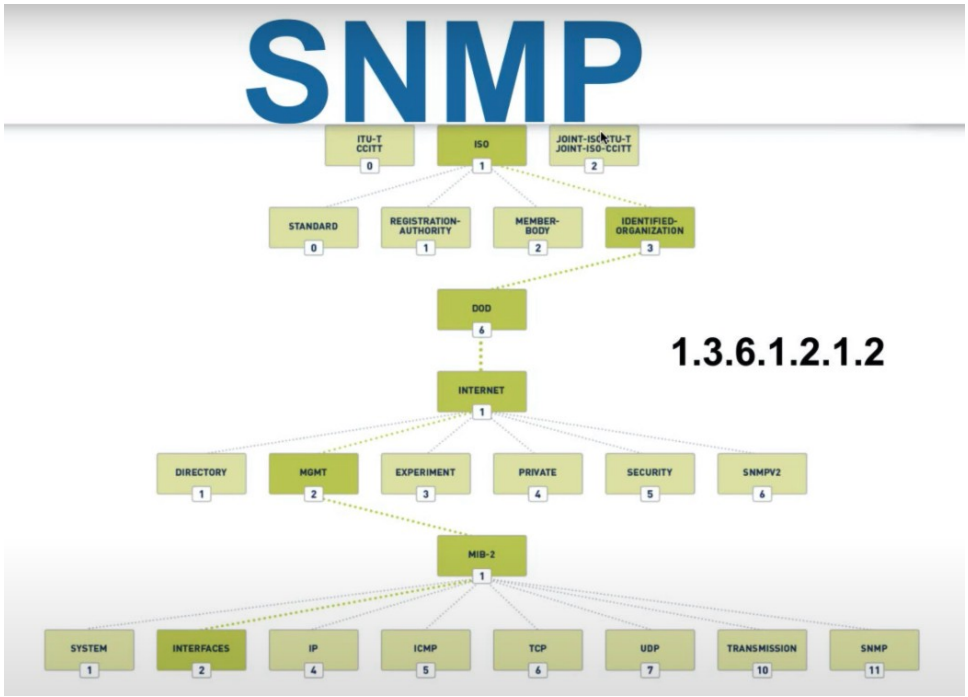
El Protocolo Simple de Administración de Red (SNMP) es un protocolo estándar de Internet para recopilar y organizar información sobre dispositivos gestionados en redes IP, así como para modificar dicha información con el fin de cambiar el comportamiento de los dispositivos. (eG Innovations, s. f.).

SNMP expone datos de gestión en forma de variables en los sistemas administrados, organizados en una base de información de gestión (MIB), que describen el estado y la configuración del sistema. Estas variables pueden ser consultadas de forma remota (y, en algunos casos, modificadas) por aplicaciones de gestión. (eG Innovations, s. f.).

Por convención, la mayoría de los equipos SNMPv1/v2c salen de fábrica con una cadena de comunidad de solo lectura configurada como "public". Es una práctica recomendada que los administradores de red cambien todas las cadenas de comunidad a valores personalizados en la configuración del dispositivo. (Paessler, s. f.).

La vulnerabilidad CVE-1999-0517 consiste en que el agente SNMP utiliza la cadena de comunidad por defecto “public”, lo cual permite a un atacante sin autenticación consultar los objetos SNMP del dispositivo. Ya que SNMPv1/v2c transmite la comunidad en texto claro, un atacante podría capturarla fácilmente y reutilizarla en consultas futuras. El problema se encuentra en que, si no se cambia la cadena predeterminada, cualquiera en la red podría realizar solicitudes SNMP de lectura y sacar información crítica del dispositivo. En este contexto, un OID (Object Identifier) es un número que identifica de forma única cada atributo o variable dentro de la MIB (Management Information Base), por ejemplo “1.3.6.1.2.1.1.1.0” para la descripción del sistema; con la comunidad “public” activa, un atacante puede usar ese OID para extraer datos como el nombre del host, la versión del kernel y el tiempo de actividad.

FIGURA 1: Diagrama de interpretación de OID



Fuente: Fotograma del vídeo “Configuración SNMP”, canal de YouTube de Teslag Training.

1.2 Normas ISO/IEC relevantes para la vulnerabilidad SNMP por defecto

- **ISO/IEC 27001:2022 (SGSI):** Ofrece controles que deben aplicarse para proteger los servicios de la red y controlar las vulnerabilidades. En concreto, el control A 8.21 de seguridad del servicio de red pide autenticación, cifrado y alguna medida de control de acceso para evitar que la información se filtre o se acceda a los servicios en exposición, y el control A.12.6.1 que controla la gestión de la vulnerabilidad técnica y añade un requisito que se encarga de catalogar una lengua y versión de una vulnerabilidad y aplicar un parche o remedio.

- **ISO/IEC 27002:2022 (Controles de seguridad de la información):** Complementa a la 27001 con controles específicos. En concreto, el control 13.1.1 Controles de red, que menciona que la organización debe administrar y controlar las redes que soportan los servicios de información para garantizar la seguridad de la información que se comunica y procesa en los sistemas, aplicaciones y servicios web, y el control 13.1.2 Seguridad de los servicios de red, que menciona que todos los servicios de red, incluidos los servicios en la nube, deben reunir y utilizar protocolos y plataformas seguros, con estos elementos documentados en los acuerdos de servicio.

- **ISO/IEC 27033 (Seguridad en redes de TI):** Ofrece normas que se centran en el diseño y operación segura de redes. En concreto, menciona que “Existen riesgos significativos con SNMP versión 1 y versión 2 que tienen poca o ninguna seguridad. Por lo tanto, si una organización decide utilizar SNMP, debería utilizar la versión 3 con controles de seguridad completos”. Esto indica directamente que la comunidad por defecto de SNMPv1/v2 es inaceptable y se debe usar SNMPv3 con autenticación y cifrado. Además, pide registrar eventos de red, incluso traps SNMP, y auditar los sistemas para detectar usos indebidos.

1.3 Relevancia actual de la vulnerabilidad dentro de seguridad de sistemas

Aunque CVE-1999-0517 es un identificador antiguo, en la actualidad la práctica de dejar cadenas SNMP por defecto sigue siendo común y es aprovechada en ataques reales. Por ejemplo, una alerta conjunta de varias agencias (NCSC del Reino Unido, FBI, NSA y CISA) de abril de 2023 informó que actores patrocinados por un estado usaron cadenas comunitarias débiles incluyendo la estándar “public” para hacer reconocimiento en routers Cisco vulnerables. También se reportó que el grupo APT28/Fancy Bear enmascaró tráfico para acceder a SNMP de routers Cisco globales, y que “cadenas comunitarias SNMP débiles, incluido el ‘public’ predeterminado, permitieron a APT28 obtener información del router y listar sus interfaces”. En ambos casos, los atacantes usaron esas comunidades para extraer la configuración del dispositivo y así mapear la red.

Adicionalmente, muchos dispositivos de red periféricos (cámaras IP, impresoras de red, UPS gestionables, módems, switches caseros, etc.) suelen venir con SNMP habilitado y cadenas por defecto. En el blog Rapid7 se indica que en pruebas de penetración es habitual encontrar estos dispositivos con SNMP configurado mediante “passwords” obvios. En pocas palabras, la exposición de la cadena predeterminada “public” en SNMP es un claro ejemplo de credenciales por defecto y encaja con la prueba Testing for Default Credentials (**OTG-AUTHN-002**, **sección 4.4.2**) de la Guía de Pruebas de Seguridad de OWASP v4, la cual pertenece a la categoría “**A05:2021** Security Misconfiguration del OWASP Top 10”, donde se comprueba si no se utilizan valores por defecto como “public” o “private” para acceder a interfaces críticas y se documentan los riesgos de filtración de información de red.

1.4 Objetivos de la prueba

1.4.1 Objetivo General

Demostrar de manera práctica la vulnerabilidad (CVE-1999-0517) siguiendo el marco de la “OWASP Testing Guide v4, OTG-AUTHN-002, sección 4.4.2, Testing for Default Credentials, A05:2021 Security Misconfiguration”, realizando la extracción de información sensible de un dispositivo conectado a la red, e identificar el riesgo de esta acción y dar a conocer las implicaciones dentro de un entorno controlado.

1.4.2 Objetivos específicos

Para lograr el objetivo general se plantean los siguientes objetivos específicos:

- Montar un laboratorio de prueba con un agente SNMPv1/v2c configurado con la comunidad por defecto “public”.

- Verificar si el puerto “UDP 161” es accesible y si el servicio SNMP se encuentra habilitado en el dispositivo objetivo.

- Verificar si el agente SNMP permite peticiones con comunidad “public”, y se encuentra habilitado previamente a cualquier autenticación.

- Realizar una extracción de datos de la “MIB” mediante modo lectura (sysDescr, sysName, interfaces, direcciones IP, rutas, tablas ARP, sysContact, etc), utilizando herramientas como snmpwalk y scripts NSE de Nmap.

2 METODOLOGÍA

2.1 Descripción del entorno de prueba

Se montó un laboratorio en una estación de trabajo física, sobre la cual corre un virtualizador y en ella se hospeda la máquina virtual objetivo. A continuación se detallan todos los componentes y configuraciones:

2.1.1 Topología de la red de pruebas

El equipo físico Kali Linux se conecta directamente a la LAN real mediante su interfaz eth0 en modo “bridge”, recibiendo la IP estática 192.168.0.20/24, mientras que la máquina virtual que aloja Ubuntu comparte esa misma conexión de puente VMnet0. De esta forma, tanto el servidor SNMP vulnerable (192.168.0.35) como el dispositivo atacante (192.168.0.20) conviven en la misma subred (192.168.0.0/24) y pueden intercambiar paquetes directamente sin NAT ni segmentación adicional. Esta disposición permite simular comunicaciones reales en la LAN como si ambos dispositivos estuviesen físicamente conectados al mismo router y facilita las pruebas de detección, enumeración y explotación de SNMP en un entorno controlado.

FIGURA 2: Topología del laboratorio representada con MIRO

Fuente: Elaboración propia.

2.1.2 Equipo anfitrión (Kali Linux 2025.1)

- **Sistema operativo:** Kali Linux 2025.1 LTS
- **Kernel:** 6.12.25-amd64.
- **Entorno de Escritorio:** GNOME 48.0.
- **CPU:** Intel Core i5-8250U (4 núcleos a 3.6 GHz).
- **RAM:** 16 GiB DDR4-3200 MHz.

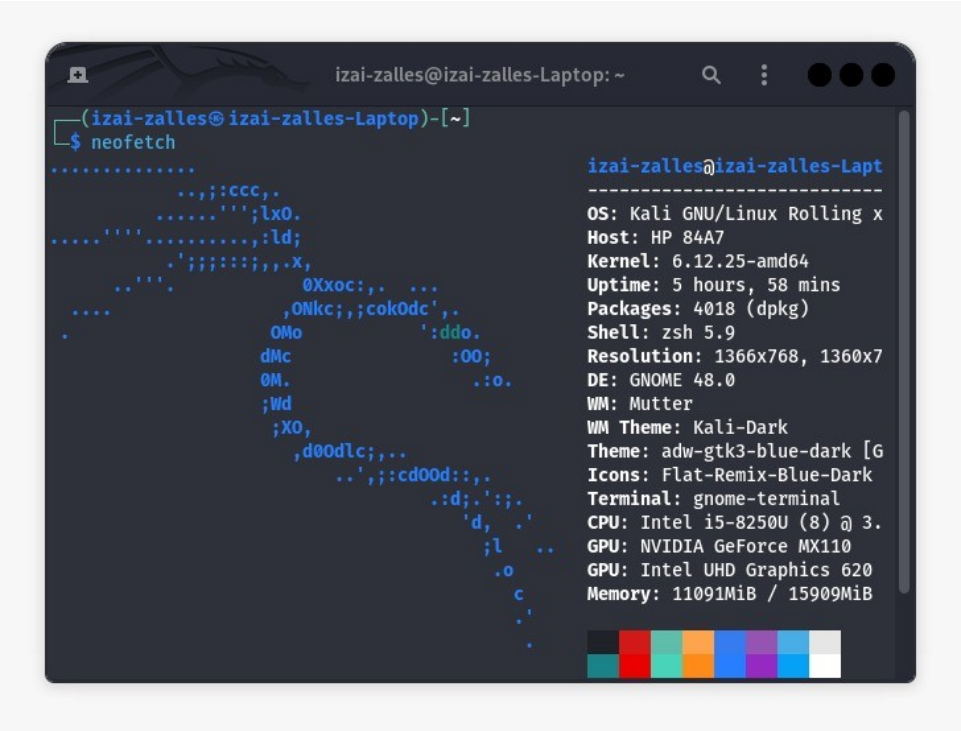
- **Almacenamiento principal:** SATA HDD 931.51 GiB.

- **GPU dedicada:** NVIDIA GeForce MX110.

- **Red física:** Realtek RTL8111/8168 Gigabit Ethernet (eth0, 1000 Mbps full-duplex), IP estática 192.168.0.20/24.

- **Software de visualización:** VMware Workstation Pro 17.6.3 con VMware Tools 12.4.0.

FIGURA 3: Información del sistema mostrada por Neofetch en Kali Linux.

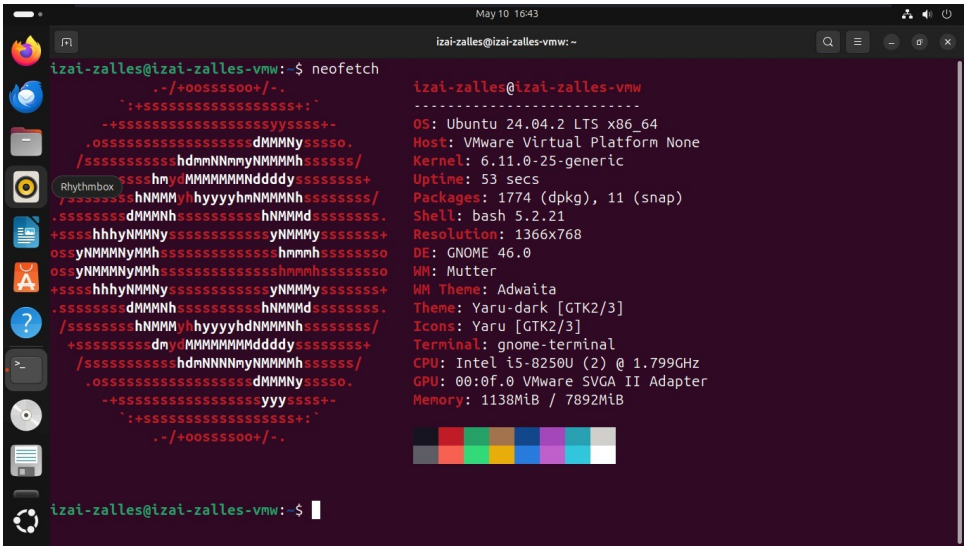


Fuente: Elaboración propia.

2.1.3 Equipo virtual objetivo (Ubuntu 24.04.2 LTS)

- **Sistema operativo:** Ubuntu 24.04.2 LTS
- **Kernel:** 6.11.8-25-amd64.
- **Entorno de escritorio:** GNOME 46.8
- **CPU virtual:** 4 vCPU extraídas del host.
- **RAM virtual:** 8 GiB reservado.
- **Almacenamiento virtual:** 20 GiB.
- **GPU virtual:** VMware SVGA II con 1 GiB de VRAM.
- **Red:** Bridge a la red física, IP estática 192.168.0.35/24.

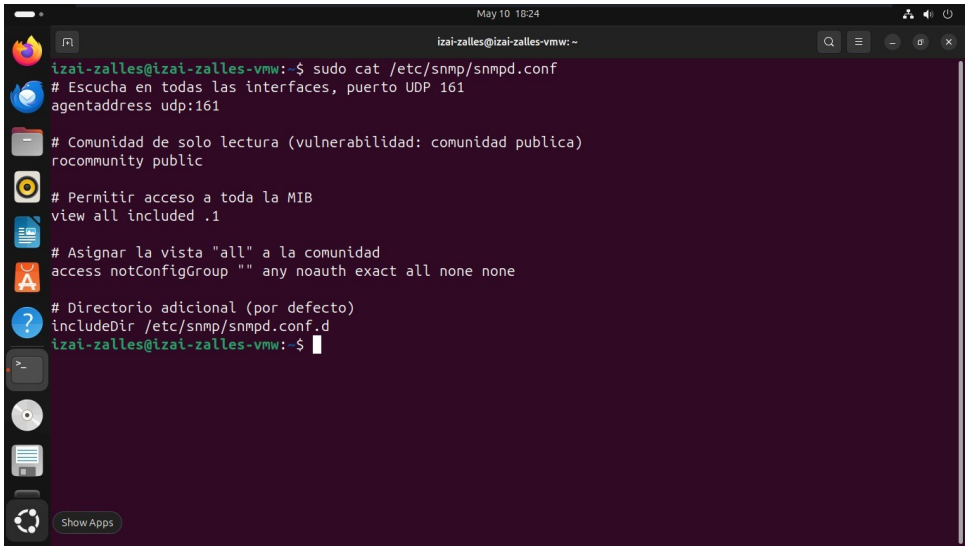
FIGURA 4: Información del sistema mostrada por Neofetch en Ubuntu Linux.



Fuente: Elaboración propia.

- De acuerdo con la guía de pruebas (OWASP OTG-AUTHN-002), se verifica el agente SNMP en su estado actual, que se encuentra escuchando en todas las interfaces y utiliza la comunidad de solo lectura “public” con acceso completo a la MIB mediante la vista “all”, además de incluir por defecto el directorio /etc/snmp/snmpd.conf.d para configuraciones adicionales, y así mismo entender cómo está funcionando el servicio actualmente.

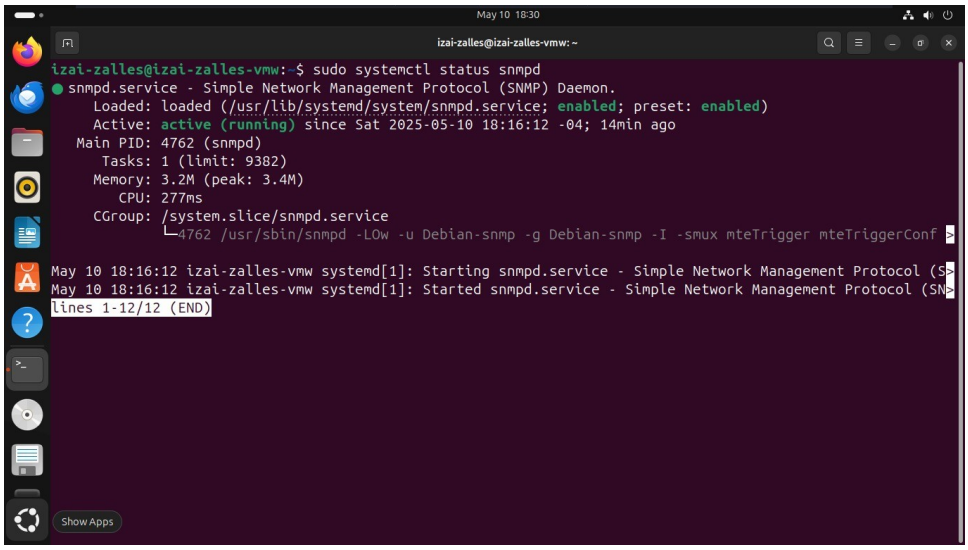
FIGURA 5: Contenido del archivo snmpd.conf mostrado por cat en Ubuntu Linux



Fuente: Elaboración propia.

- El servicio SNMP se encuentra en estado “Active” corriendo.

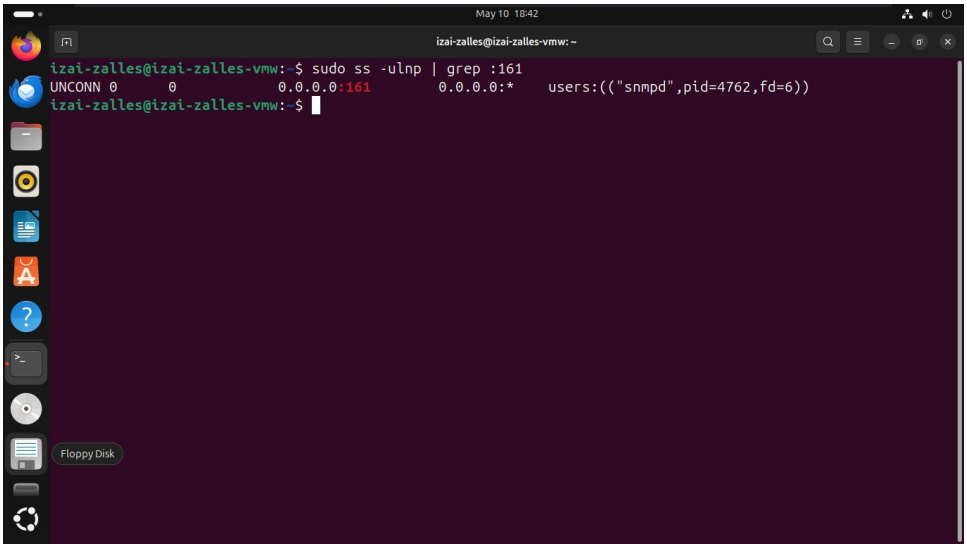
FIGURA 6: Estado del servicio SNMP mostrado por systemctl en Ubuntu Linux



Fuente: Elaboración propia.

- El sistema está escuchando en el puerto UDP 161.

FIGURA 7: Puerto que el sistema se encuentra escuchando mostrado por ss y filtrado por grep en Ubuntu Linux



Fuente: Elaboración propia.

2.2 Herramientas utilizadas

Para verificar la vulnerabilidad SNMP con comunidad por defecto (CVE-1999-0517), se escogieron dos herramientas de software libre: **SNMPWalk**, que forma parte de la suite Net-SNMP, y **Nmap**. **Estas herramientas se escogieron por su efectividad demostrada en auditorías de SNMP pasadas y por ser de código abierto**, lo que facilita su uso y reproducción en entornos de pruebas. A continuación se presenta la descripción de cada herramienta:

- **Nmap:** Fue escogido porque permitir escanear rangos de direcciones completos, identificando múltiples dispositivos con SNMP habilitado de manera simultánea. Ademas de su motor NSE que incluye scripts específicos para SNMP. Al ser software libre dispone de una gran comunidad de desarrollo y actualizaciones constantes.

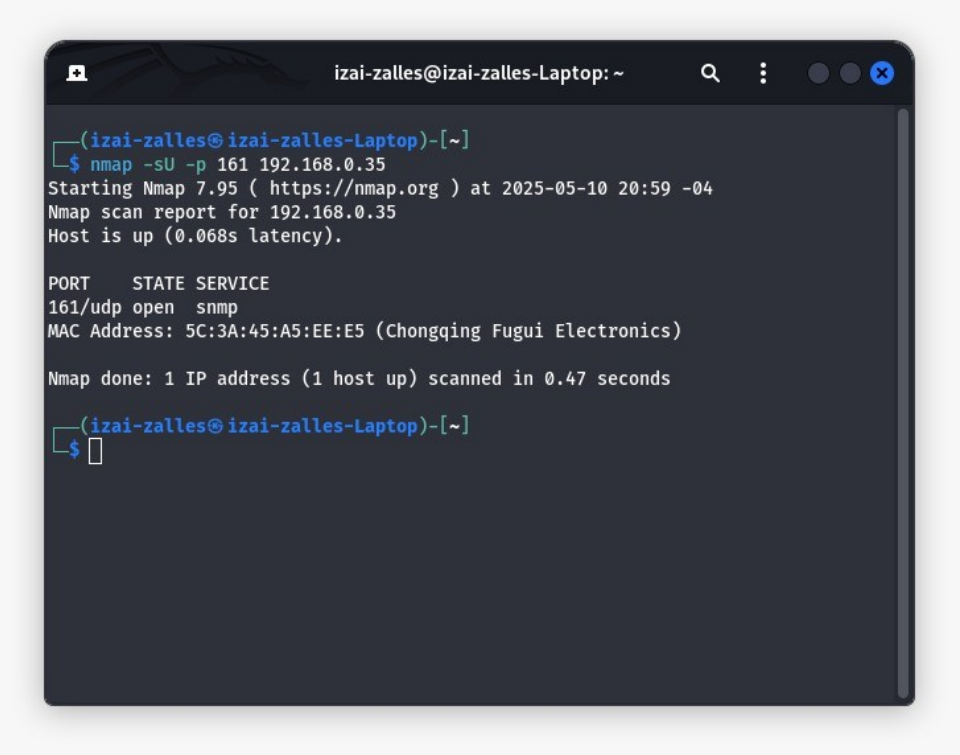
- **SNMPWalk:** Fue escogido por ser una herramienta especifica para consultas SNMP, que permite acceder directamente a los valores de la MIB en lugar de limitarse a detectar la existencia del servicio. SNMPWalk ofrece mayor flexibilidad para automatizar consultas específicas y filtrar por OID.

2.3 Pasos seguidos para realizar la prueba

Siguiendo la guía de pruebas de OWASP v4, específicamente la prueba "OTG-AUTHN-002", a continuación se describen las acciones para demostrar la vulnerabilidad "CVE-1999-0517":

- Detección del servicio SNMP en el puerto UDP 161 mediante el comando "nmap -sU -p 161 192.168.0.35" ejecutado desde Kali Linux, identificando los equipos que responden con SNMP activo. El parámetro "-sU" indica a Nmap que realice un escaneo UDP en lugar del escaneo TCP predeterminado, mientras que "-p" 161 especifica que se debe comprobar exclusivamente el puerto 161, utilizado por defecto por el protocolo SNMP. Esta combinación permite verificar de forma rápida si el puerto SNMP se encuentra abierto en el dispositivo objetivo y si responde a consultas, sin necesidad de escanear otros servicios no relevantes para la prueba.

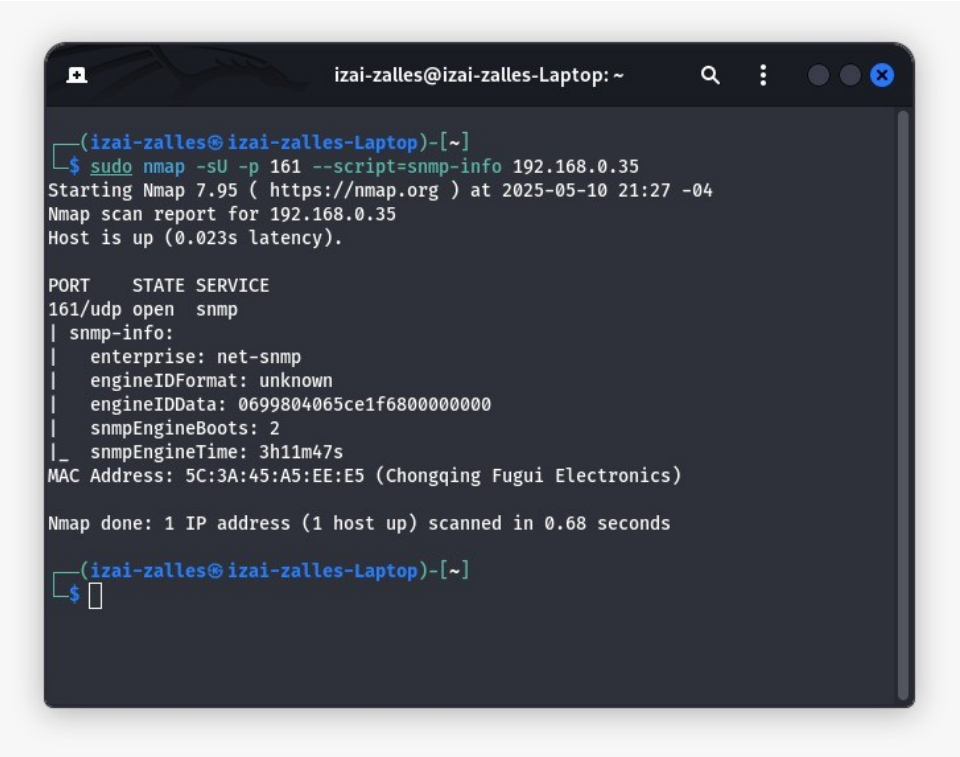
FIGURA 8: Escaneo de puertos mostrado por nmap en Kali Linux



Fuente: Elaboración propia.

- Realizar un fingerprinting básico del servicio SNMP mediante el comando "sudo nmap -sU -p 161 --script=snmp-info 192.168.0.35", ejecutado desde Kali Linux, extrayendo parámetros generales del agente SNMP, como la versión, el nombre del sistema y el identificador de la organización. El parámetro "--script=snmp-info" indica que se utilice el script NSE llamado "snmp-info", el cual consulta de forma no intrusiva la MIB del dispositivo a través de la comunidad por defecto “public” para obtener información básica de configuración y del sistema, como el nombre del host, sistema operativo y uptime, sin necesidad de autenticación.

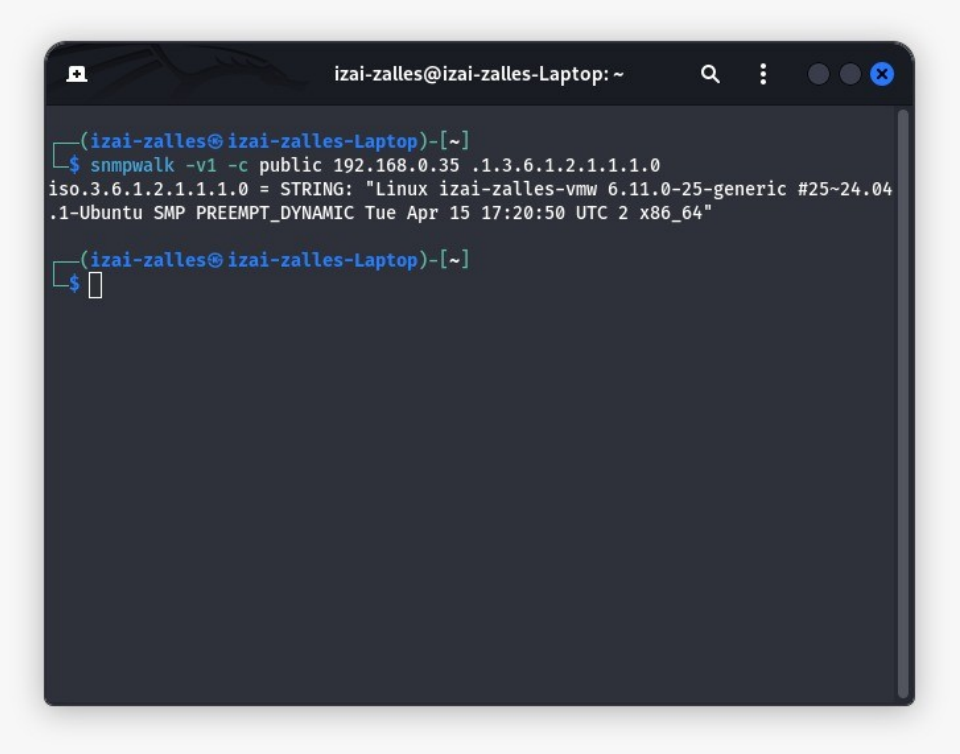
FIGURA 9: Consulta de MIB del dispositivo objetivo por nmap en Kali Linux.



Fuente: Elaboración propia.

- Prueba y búsqueda de comunidad por defecto con el comando "snmpwalk -v1 -c public 192.168.0.35 .1.3.6.1.2.1.1.1.0" para verificar si “public” funciona sin autenticación, donde el parámetro "-v1" especifica el uso del protocolo SNMP versión 1, "-c public" indica la cadena de comunidad a emplear y .1.3.6.1.2.1.1.1.0 es el identificador numérico (OID) que apunta al objeto sysDescr.0, cuya respuesta contiene la descripción del sistema.

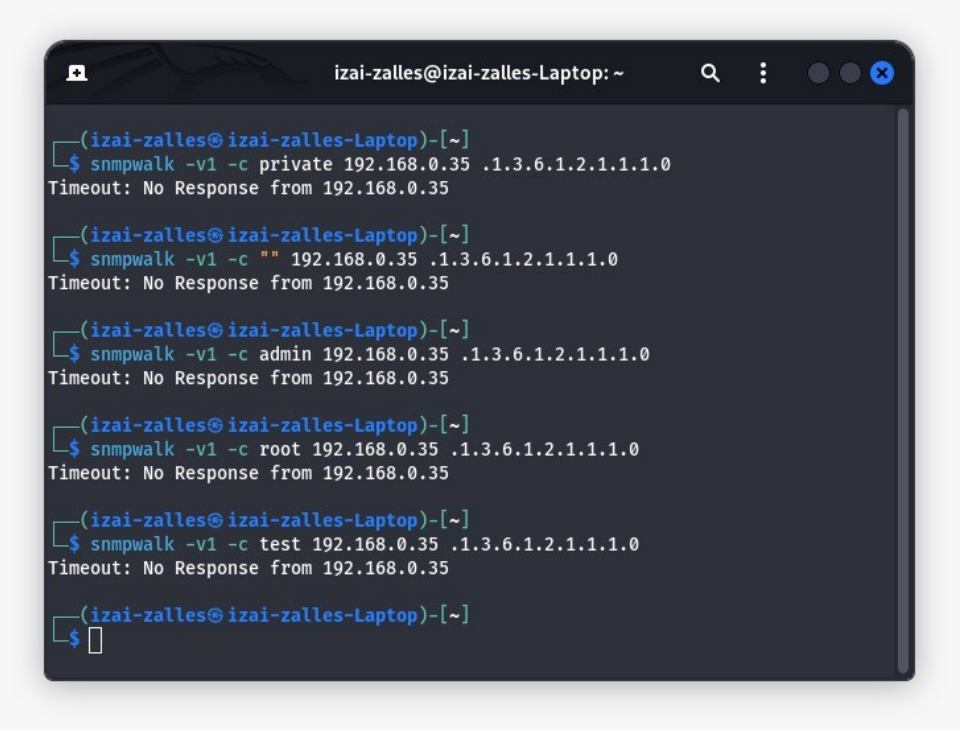
FIGURA 10: Verificación del funcionamiento de “public” sin autenticación del dispositivo objetivo por snmpwalk en Kali Linux.



Fuente: Elaboración propia.

- Además de la cadena predeterminada “public”, se realizan intentos con otras comunidades comúnmente utilizadas como “private”, una cadena vacía, “admin”, “root” y “test”, para comprobar si el dispositivo respondía sin autenticación. Cada intento utilizó el OID .1.3.6.1.2.1.1.1.0, que corresponde al objeto sysDescr.0, el cual devuelve una descripción general del sistema si el acceso es exitoso.

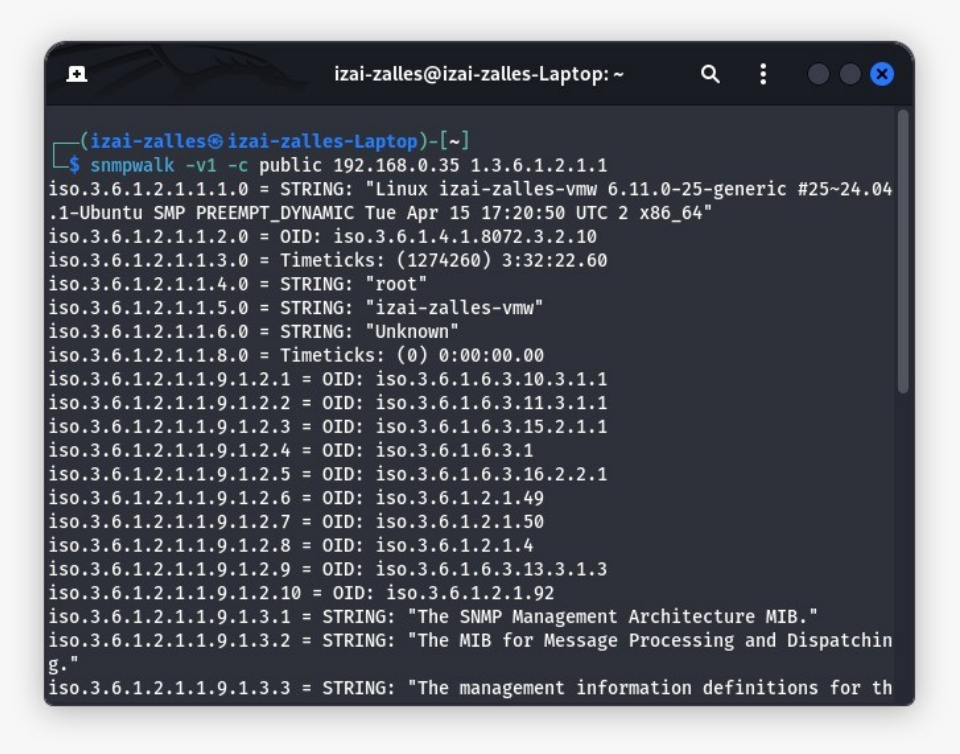
FIGURA 11: Prueba de cadenas predeterminadas variadas mostrada y realizada por snmpwalk en Kali Linux.



Fuente: Elaboración propia.

- Extracción del grupo system con el comando "snmpwalk -v1 -c public 192.168.0.35 1.3.6.1.2.1.1" para recoger todos los objetos de “MIB-II system”. Donde el OID 1.3.6.1.2.1.1 corresponde al subárbol system definido, que agrupa variables como sysDescr (descripción del sistema), sysObjectID (identificador de implementación), sysUpTime (tiempo de actividad), sysContact (contacto del administrador), sysName (nombre del host), sysLocation (ubicación física) y sysServices (servicios habilitados). Al recorrer esta rama, se obtiene de manera automática y secuencial la información básica del dispositivo, confirmando que la comunidad “public” permite el acceso sin autenticación y exponiendo datos esenciales para el reconocimiento inicial.

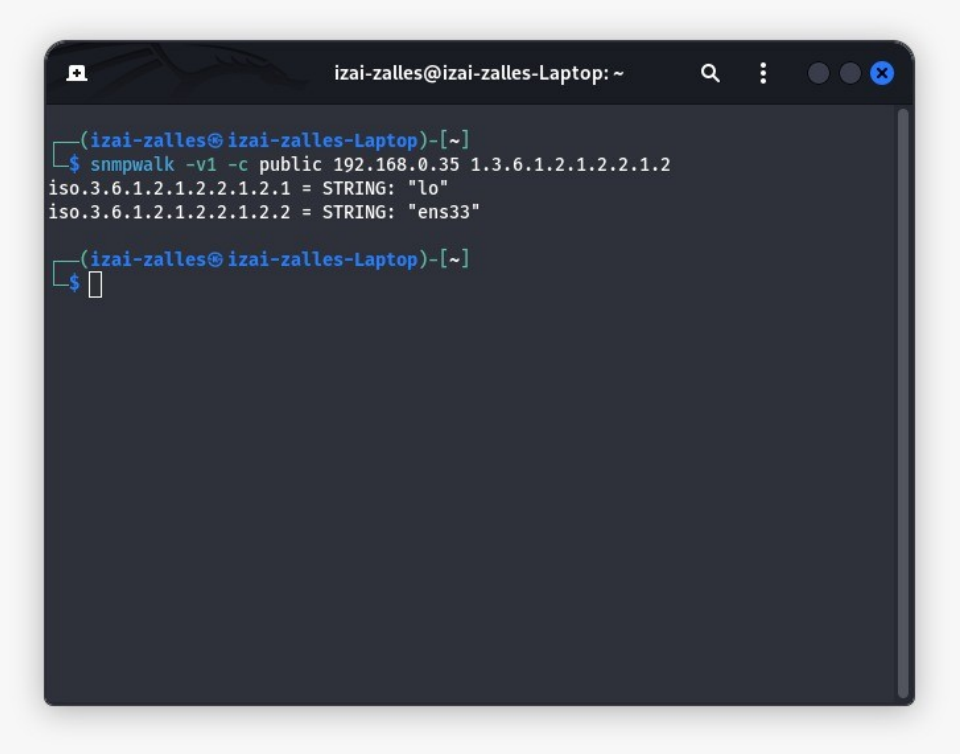
FIGURA 12: Extracción de los objetos de MIB-II system del dispositivo objetivo por snmpwalk en Kali Linux.



Fuente: Elaboración propia.

- Enumeración de interfaces de red con el comando "snmpwalk -v1 -c public 192.168.0.35 1.3.6.1.2.1.2.2.1.2", donde el OID 1.3.6.1.2.1.2.2.1.2 corresponde a la rama “IF-MIB::ifDescr”, que define la descripción textual de cada interfaz de red, permitiendo listar y reconocer cómo se identifican y nombran las interfaces en el dispositivo objetivo.

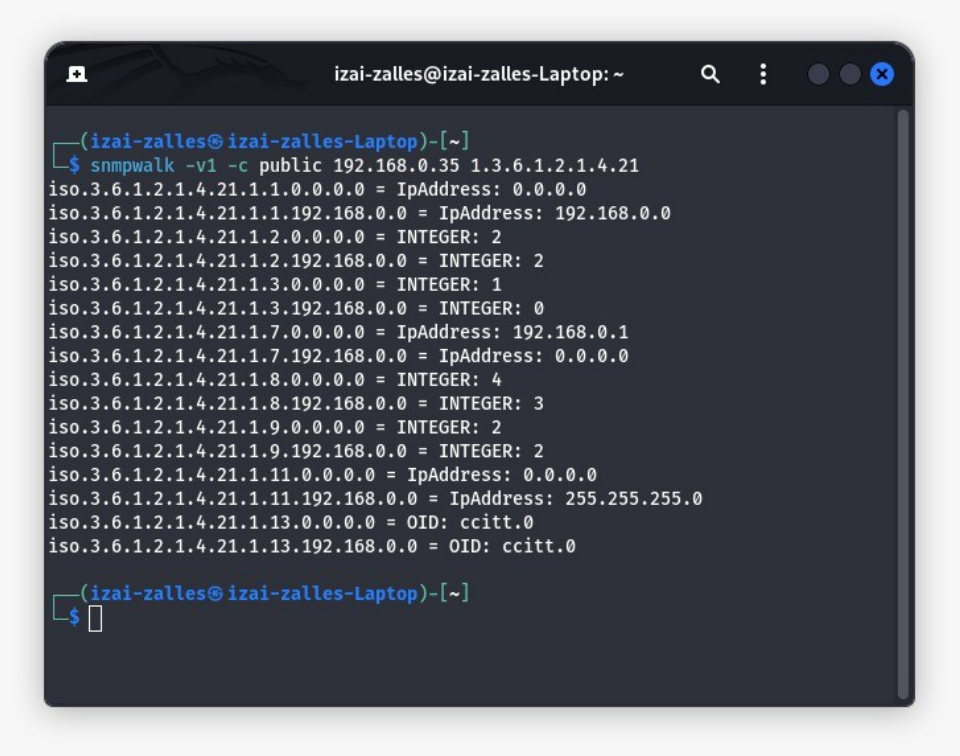
FIGURA 13: Enumeración de interfaces de red del dispositivo objetivo por snmpwalk en Kali Linux.



Fuente: Elaboración propia.

- Listado de rutas IP con el comando "snmpwalk -v1 -c public 192.168.0.35 1.3.6.1.2.1.4.21", donde el OID 1.3.6.1.2.1.4.21 corresponde a la "IP-MIB::ipRouteTable", que agrupa las entradas de la tabla de enrutamiento del dispositivo, permitiendo extraer de manera estructurada toda la información sobre rutas configuradas en el sistema.

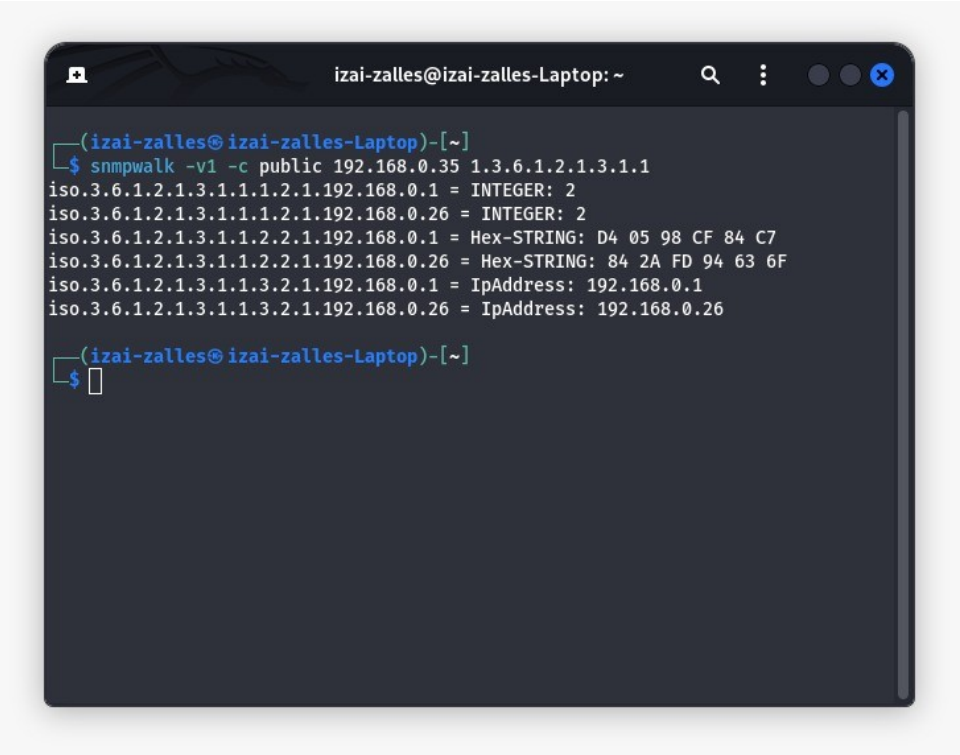
FIGURA 14: Listado de rutas IP del dispositivo objetivo por snmpwalk en Kali Linux.



Fuente: Elaboración propia.

- Extracción de la tabla ARP con el comando "snmpwalk -v1 -c public 192.168.0.35 1.3.6.1.2.1.3.1.1", donde el OID 1.3.6.1.2.1.3.1.1 pertenece a la rama "IP-MIB::ipNetToMediaTable", que almacena el mapeo entre direcciones IP y direcciones MAC aprendidas por el dispositivo, revelando qué hosts están conectados y en qué interfaces.

FIGURA 15: Extracción de tabla ARP del dispositivo objetivo por snmpwalk en Kali Linux.



Fuente: Elaboración propia.

3 RESULTADOS

3.1 Descripción de los resultados obtenidos

3.1.1 Análisis del Puerto SNMP UDP 161

Se detectó que el puerto UDP 161 en el host 192. 168. 0. 35 estaba accesible. Este hallazgo ratifica que el servicio SNMP está activo. La utilidad Nmap mostró el estado abierto, lo cual denota que el puerto está dispuesto a recibir y contestar a paquetes UDP. Esto sugiere que un agente SNMP está funcionando en el dispositivo examinado, lo que abre la puerta para ejecutar evaluaciones más detalladas sobre la posible divulgación de datos vía SNMP.

3.1.2 Fingerprinting del servicio SNMP

La secuencia de comandos “snmp-info” de Nmap pudo extraer la información del agente SNMP, revelando el ID empresarial “net-snmp”, los datos del ID del motor, la cantidad de veces que se reinició el servicio y su tiempo en funcionamiento, junto con la dirección MAC. Claramente, esto evidencia que se puede acceder al servicio SNMP sin necesidad de autenticación alguna, y que responde a preguntas sencillas con la configuración predeterminada, lo que indica una configuración inadecuada del equipo.

3.1.3 Comprobación de acceso no autenticado usando la comunidad "public"

Al usar "snmpwalk" en la versión 1 con la comunidad "public", quedó en evidencia que el agente SNMP tenía una configuración incorrecta. Seguía usando la cadena "public" predeterminada, lo que concuerda con la vulnerabilidad CVE-1999-0517. Además, probamos con cadenas usuales como "private", "admin", "root", "test" y hasta dejamos el campo vacío, pero no obtuvimos nada. Esto indicaba que la única vía de acceso era la cadena "public", confirmando que, en efecto, el dispositivo era vulnerable.

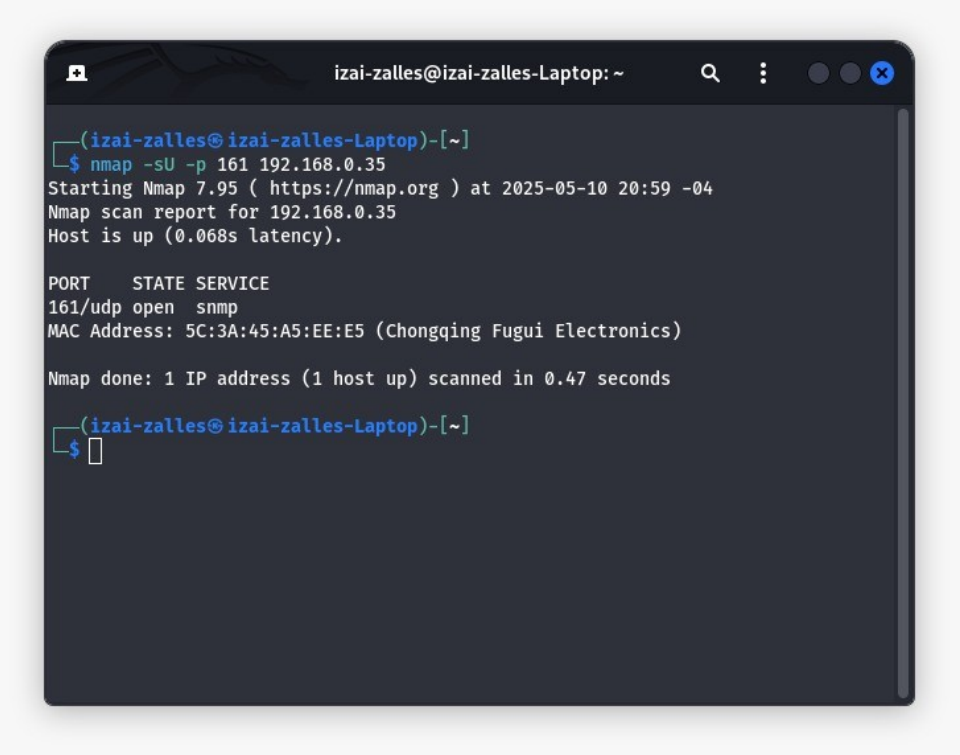
3.1.4 Extracción de la información del dispositivo

Se consiguió información específica del dispositivo analizado la sección “MIB 1. 3. 6. 1. 2. 1. 1”, sacando datos como el nombre del dispositivo, la versión del kernel, el nombre de usuario y el tiempo que el equipo lleva funcionando. Además, se identificaron las interfaces activas, como eth0, revisando la sección correspondiente de la MIB. También se extrajo la tabla de enrutamiento (IP-MIB::ipRouteTable), que mostró las rutas del dispositivo, incluyendo direcciones IP de destino, máscaras de red y gateways asociados. Finalmente, se obtuvo a la tabla ARP (IP-MIB::ipNetToMediaTable), obteniendo la relación entre direcciones IP y direcciones MAC correspondientes a la interfaz.

3.2 Evidencia de la vulnerabilidades

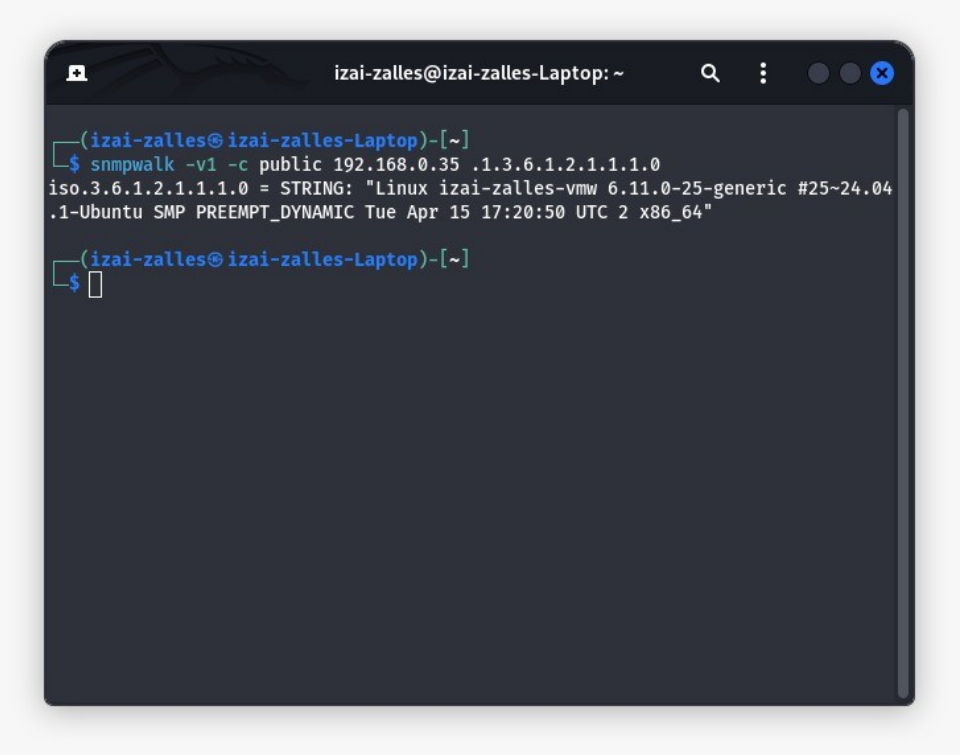
Las siguientes figuras muestras los comandos ejecutados y las respuestas del sistema como evidencia de la vulnerabilidad:

FIGURA 16: Puerto UDP 161 abierto mostrado por Nmap en Kali Linux.



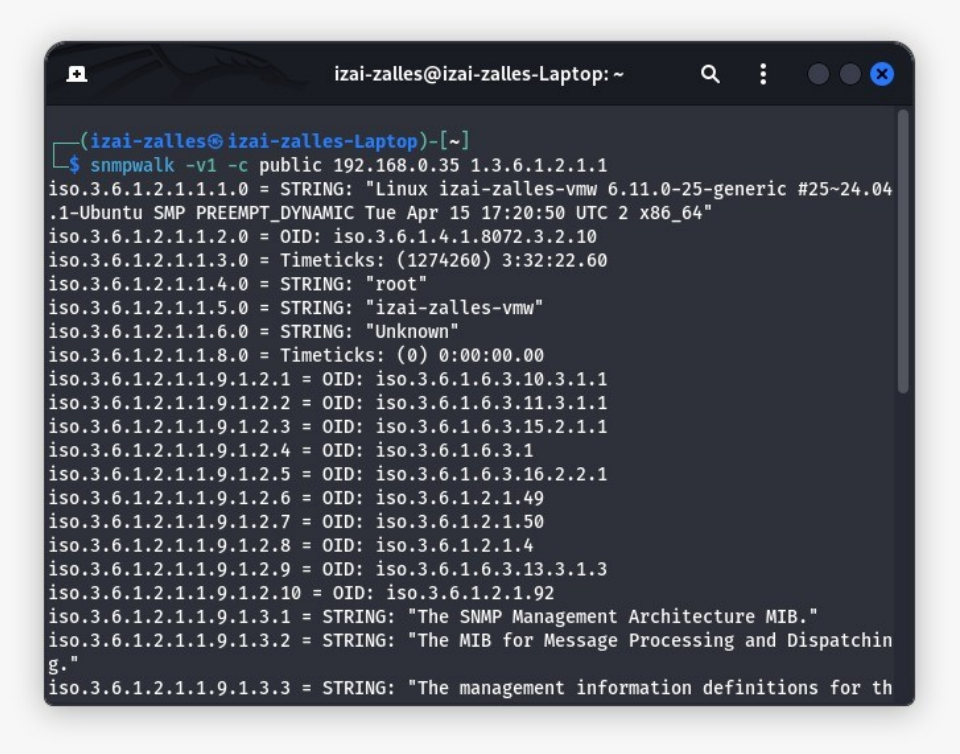
Fuente: Elaboración propia.

FIGURA 17: Respuesta exitosa a snmpwalk mostrando el sysDescr en Kali Linux.



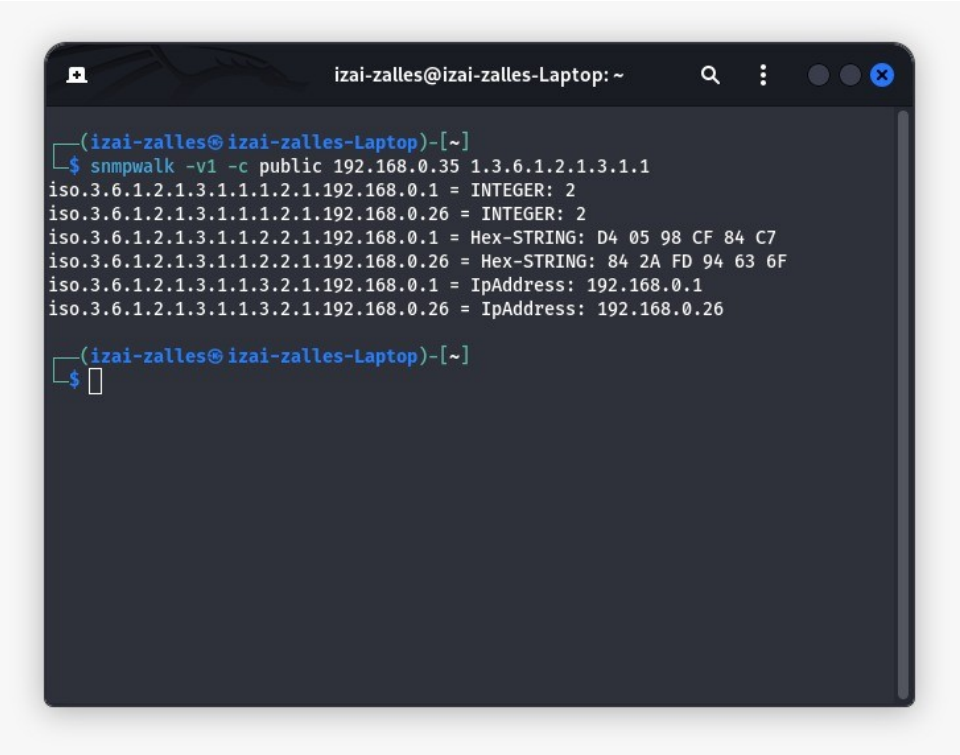
Fuente: Elaboración propia.

FIGURA 18: Extracción de objetos system desde el MIB-II mostrado por snmpwalk en Kali Linux.



Fuente: Elaboración propia.

FIGURA 19: Tabla ARP extraída y mostrada por snmpwalk en Kali Linux.



Fuente: Elaboración propia.

3.3 Análisis del impacto potencial de la vulnerabilidad en un sistema real

La vulnerabilidad demostrada representa un riesgo significativo para la seguridad de los sistemas en producción. El compromiso de la confidencialidad de la información constituye uno de los impactos más fuertes y graves. Como demostraron las pruebas realizadas, un atacante puede obtener sin autorización detalles críticos del sistema, como la versión del kernel, tiempo de actividad y nombre del equipo. Esta información facilita la identificación precisa del sistema operativo y sus versiones específicas, permitiendo al atacante buscar vulnerabilidades específicas.

La exposición de la topología de red representa otro riesgo importante. La información extraída de la MIB revela interfaces activas, tabla de enrutamiento y tabla ARP, proporcionando al atacante la capacidad de mapear a detalle la estructura interna de la red del dispositivo objetivo. Este conocimiento detallado permite identificar los dispositivos de la red, segmentación de red y rutas para atacar. Además, las variables SNMP contienen datos de configuración sensibles como puntos de acceso inalámbricos, direcciones IP internas, nombres de usuarios del sistema y roles del dispositivo.

En entornos industriales, esta vulnerabilidad puede causar daños graves. En sectores como el energético, un atacante podría obtener información detallada sobre los equipos, como configuraciones de los sistemas SCADA y su arquitectura. En el área de salud, los dispositivos médicos conectados mediante SNMP con configuración predeterminada pueden comprometer directamente la seguridad del paciente, ya que configuraciones y tratamientos dentro de los dispositivos pueden ser alterados.

Las implicaciones económicas y operativas de esta vulnerabilidad pueden llegar a ser muy altas. Las empresas pierden dinero desde el momento en que la vulnerabilidad está en marcha hasta el momento en que se mitiga. Muchas veces los daños ocasionados por este tipo de vulnerabilidades pueden llegar a ser irreversibles y a afectar a muchas personas.

Con base en los resultados obtenidos, podemos confirmar que las pruebas fueron realizadas con **éxito**, realizando de forma correcta la prueba de credenciales por defecto OWASP (OTG-AUTHN-002)

4 ANÁLISIS Y DISCUSIÓN

4.1 Causas de la vulnerabilidad y comparación con vulnerabilidades similares

En nuestro entorno de laboratorio, hemos verificado que la principal causa de la vulnerabilidad de divulgación de cadena de comunidad por defecto se encuentra en la configuración predeterminada del agente SNMP. La configuración presentaba múltiples debilidades, como:

- **Uso de la comunidad "public":** El agente SNMP estaba configurado con la cadena de comunidad predeterminada "public", lo que permitía a cualquier atacante acceder a la información del sistema sin proporcionar credenciales.

- **Implementación de versiones inseguras:** El uso de SNMPv1/v2c transmite la cadena de comunidad en texto plano, lo que facilitaba la interceptación de esta información mediante análisis de tráfico.

- **Acceso no restringido:** La configuración view all included .1 otorgaba acceso completo a toda la estructura MIB, exponiendo información crítica como tablas de enrutamiento, detalles de interfaces y datos del sistema.

En comparación con otras vulnerabilidades similares, como el uso de credenciales predeterminadas en interfaces de administración web contemplado en OWASP A05:2021 Security Misconfiguration, la vulnerabilidad CVE-1999-0517 presenta características particulares:

- **Amplio alcance:** Afecta a una diversidad de dispositivos, desde infraestructura de red empresarial hasta dispositivos IoT y equipamiento industrial.

- **Impacto inicial aparentemente limitado:** A diferencia de vulnerabilidades que permiten la toma de control total, esta vulnerabilidad solo permite acceso a información. Sin embargo, los datos expuestos facilitan ataques posteriores más sofisticados.

4.2 Evaluación del cumplimiento normativo

Los resultados de la prueba evidencian un incumplimiento directo de varios controles establecidos en las normas ISO/IEC.

- **ISO/IEC 27001:2022 (control A.8.21):** La configuración del servicio SNMP con la comunidad por defecto incumple el requisito de autenticación adecuada para los servicios de red.

- **ISO/IEC 27002:2022 (control 13.1.2):** El servicio SNMP configurado con SNMPv1/v2c y comunidad "public" no cumple con el requisito de utilizar protocolos y plataformas seguras.

- **ISO/IEC 27033:** La prueba confirmó exactamente lo que esta norma advierte sobre los "riesgos significativos con SNMP versión 1 y versión 2 que tienen seguridad débil o inexistente".

El incumplimiento de estas normas representa un grave problema de cumplimiento regulativo que podría tener implicaciones legales y financieras para las organizaciones que operan bajo marcos normativos estrictos.

4.3 Limitaciones de la prueba realizada

La prueba realizada presenta las siguientes limitaciones que deben ser consideradas:

- **Entorno controlado:** Nuestro laboratorio utilizó una máquina virtual Ubuntu 24.04.2 LTS en un entorno controlado. En entornos de producción, las interacciones con otros sistemas y configuraciones complementarias pueden introducir variables adicionales.

- **Ausencia de análisis postexplotación:** La prueba se limitó a la extracción de información y no evaluó cómo esta información podría utilizarse en un ataque más amplio contra la infraestructura.

- **Dispositivo único:** La prueba se realizó atacando un solo sistema operativo sin contemplar el comportamiento de la vulnerabilidad en dispositivos embebidos, routers, switches u otros equipos que también pueden contener agentes SNMP.

4.4 Posibles variaciones o mejoras en la prueba

Para fortalecer la relevancia y aplicabilidad de esta prueba, pueden considerar las siguientes mejoras:

- **Diversificación de dispositivos objetivo:** Ampliar el alcance para incluir dispositivos de red comerciales, sistemas embebidos y equipos industriales que típicamente implementan SNMP.

- **Análisis de tráfico:** Incorporar la captura y análisis del tráfico SNMP mediante herramientas como Wireshark para demostrar la exposición de la cadena de comunidad en texto claro.

- **Escenarios de postexplotación:** Desarrollar casos prácticos que demuestren cómo la información obtenida mediante SNMP podría facilitar otros ataques como la explotación de vulnerabilidades específicas del sistema operativo identificado.

- **Prueba automatizada a escala:** Implementar scripts que puedan identificar automáticamente dispositivos vulnerables en una red completa, como lo haría un atacante real.

- **Evaluación cuantitativa del impacto:** Establecer métricas que permitan detallar el impacto potencial de la información expuesta, como el tiempo necesario para comprometer otros sistemas utilizando los datos obtenidos.

5 RECOMENDACIONES DE MITIGACIÓN

5.1 Medidas específicas para corregir la vulnerabilidad

Con base en los resultados obtenidos en nuestro entorno de pruebas, se recomiendan las siguientes medidas para mitigar la vulnerabilidad CVE-1999-0517:

- **Migración a SNMPv3:** Deshabilitar completamente SNMPv1 y SNMPv2c, e implementar únicamente SNMPv3 con autenticación y cifrado. La implementación exitosa demostró la efectividad de esta medida.

- **Implementación de vistas MIB limitadas:** Limitar el acceso solo a las secciones de la MIB necesarias para las operaciones de esta, como “view all included .1 80”, que restringe la profundidad de acceso.

- **Cambio continuo de credenciales:** Establecer un procedimiento para cambiar continuamente las contraseñas de autenticación y claves de cifrado de SNMPv3.

- **Desactivación de SNMP en sistemas que no lo necesitan:** Evaluar si realmente es necesario el servicio SNMP en todos los sistemas y desactivarlo en aquellos que no requieran monitorización constante.

5.2 Buenas prácticas de seguridad para prevenir futuras ocurrencias

Para evitar esta vulnerabilidad en un futuro, se recomienda implementar las siguientes prácticas de seguridad:

- **Auditorías regulares de configuración:** Programar revisiones regulares de la configuración de seguridad de todos los dispositivos que usen SNMP.

- **Implementación de sistemas de detección de intrusiones (IDS):** Configurar sistemas que detecten y alerten sobre intentos de escaneo o acceso no autorizado a servicios SNMP.

- **Monitorización continua del tráfico SNMP:** Implementar un análisis de tráfico que identifique patrones sospechosos o intentos de comunicación SNMP desde orígenes que no se encuentren autorizados.

- **Política de "Configuración Segura por Defecto":** Establecer que cualquier nuevo dispositivo o sistema incorporado a la red que use SNMP debe configurarse siguiendo principios de seguridad antes de su puesta en producción.

- **Gestión de riesgos según COBIT:** Realizar las prácticas de mitigación de SNMP alineadas con el dominio Ensure Risk Optimization (EDM03) de COBIT, evaluando cada fase del ciclo de riesgo y documentando la evolución de los procesos con un diagrama de Kiviat.

5.3 Consideraciones sobre la implementación de las mitigaciones

La implementación de las medidas de mitigación propuestas debe considerar los siguientes aspectos:

- **Compatibilidad con sistemas de monitorización:** Verificar que las herramientas de monitorización utilizadas en la organización soporten SNMPv3.

- **Planificación de ventanas de mantenimiento:** Programar los cambios de configuración para minimizar el impacto en la disponibilidad de los servicios.

- **Documentación de cambios:** Registrar todas las modificaciones realizadas en la configuración de SNMP, incluyendo direcciones IP autorizadas, credenciales y restricciones implementadas.

- **Pruebas previas en entorno controlado:** Similar al laboratorio montado para realizar las pruebas, validar todas las modificaciones en un entorno de prueba antes de implementarlas en producción.

- **Plan de rollback:** Preparar procedimientos para revertir rápidamente los cambios en caso de que afecten negativamente la operación de los sistemas.

- **Evaluación de impacto en el rendimiento:** Considerar que SNMPv3 con cifrado puede consumir más recursos que versiones anteriores, lo que podría afectar a dispositivos con capacidades limitadas.

- **Cumplimiento de las normas establecidas:** Asegurar que, durante la implementación de SNMPv3, se siga el plan de los procesos del **SGSI** para garantizar una migración controlada y conforme a las normas **ISO/IEC**.

6 CONCLUSIONES

6.1 Resumen de los hallazgos de la prueba

Se cumplió con el objetivo general al montar un laboratorio SNMPv1/v2c con la comunidad por defecto “public” y verificar la accesibilidad del servicio en el puerto UDP 161. Usando Nmap y snmpwalk, se demostró que únicamente “public” permitía el acceso sin autenticación, mientras que “private”, cadena vacía, “admin” y “test” fueron rechazadas, y se extrajo información sensible del dispositivo como el nombre, versión de kernel, interfaces, rutas y tabla ARP, validando la vulnerabilidad CVE-1999-0517.

6.2 Reflexiones finales sobre la importancia de la prueba realizada

Al realizar esta evaluación siguiendo la OTG-AUTHN-002 (4.4.2) Testing for Default Credentials, que pertenece a A05:2021 Security Misconfiguration, se pudo observar cómo una simple community string por defecto puede resultar en filtración de información como el mapeo de la infraestructura de red. Esta prueba demuestra la necesidad de eliminar credenciales iniciales inseguras y reforzar las configuraciones con protocolos modernos.

7 REFERENCIAS

Anidalatam. (s.f.). *Malware APT28 aprovecha vulnerabilidades en equipos de red*. Recuperado de: https://www.anidalatam.com/blog-ciberseguridad/malware-apt28-aprovecha/

Cisco. (2023, marzo 15). *Threat actors exploiting SNMP vulnerabilities in Cisco routers. Cisco Blogs – Security*. Recuperado de: https://blogs.cisco.com/security/threat-actors-exploiting-snmp-vulnerabilities-in-cisco-routers

EG Innovations. (s.f.). *SNMP (Simple Network Management Protocol)*. Recuperado de: https://www.eginnovations.com/glossary/snmp

Fortra. (s.f.). *SNMP Agent Default Community Name (public)*. Recuperado de: https://www.fortra.com/resources/vulnerabilities/snmp-agent-default-community-namepublic

GIAC. (s.f.). *UCD-SNMPD Buffer Overflow Exploit. Global Information Assurance Certification*. Recuperado de: https://www.giac.org/paper/gcih/353/ucd-snmpd-buffer-overflow-exploit/101421

Hispasec. (2002). *Grave vulnerabilidad en el protocolo SNMP*. Recuperado de: https://unaaldia.hispasec.com/2002/02/grave-vulnerabilidad-en-el-protocolo-snmp.html

Imperva. (s.f.). *Intrusion detection and prevention systems (IDPS)*. Recuperado de: https://www.imperva.com/learn/application-security/intrusion-detection-prevention/

INTE. (2022). *INTE-ISO/IEC 27035-3:2022 – Gestión de incidentes de seguridad de la información*. Recuperado de: https://es.scribd.com/document/786897361/INTE-ISO-IEC-27035-3-2022

ISA Global Cybersecurity Alliance (GCA). (s.f.). *SCADA system vulnerabilities and how to secure them. International Society of Automation (ISA)*. Recuperado de: https://gca.isa.org/blog/9-scada-system-vulnerabilities-and-how-to-secure-them

ISMS.online. (2022). *Anexo A.8.21: Seguridad de los servicios de red en ISO 27001*. Recuperado de: https://es.isms.online/iso-27001/annex-a/8-21-security-of-network-services-2022/

ISO/IEC. (2012). *ISO/IEC 27033-2:2012 – Network security – Part 2: Guidelines for the design and implementation of network security*. Recuperado de: https://www.amnafzar.net/files/1/ISO%2027000/ISO%20IEC%2027033-2-2012.pdf

ISO27000.es. (s.f.-a). *ISO 27002:2022 – Control 12. Protección de redes*. Recuperado de: https://www.iso27000.es/iso27002_12.html

ISO27000.es. (s.f.-b). *ISO 27002:2022 – Control 13. Seguridad en comunicaciones*. Recuperado de: https://www.iso27000.es/iso27002_13.html

ITSM Docs. (s.f.). *COBIT EDM03.02 - Direct risk management*. Recuperado de: https://www.itsm-docs.com/blogs/cobit-framework/cobit-edm03-02-direct-risk-management

NIST. (1999). *CVE-1999-0517 Detail. National Vulnerability Database*. Recuperado de: https://nvd.nist.gov/vuln/detail/CVE-1999-0517

Net-SNMP Project. (s.f.). *snmpwalk – Linux man page. SourceForge*. Recuperado de: https://net-snmp.sourceforge.io/docs/man/snmpwalk.html

Nmap Project. (s.f.-a). *snmp-info NSE script documentation*. Recuperado de: https://nmap.org/nsedoc/scripts/snmp-info.html

Nmap Project. (s.f.-b). *snmp-interfaces NSE script documentation*. Recuperado de: https://nmap.org/nsedoc/scripts/snmp-interfaces.html

NinjaOne. (s.f.). *Utilizar Nmap: Guía completa*. Recuperado de: https://www.ninjaone.com/es/blog/utilizar-nmap-guia-completa/

OchoBitsHacenUnByte. (2018, 3 de diciembre). *Cómo instalar y usar snmpwalk*. Recuperado de: https://www.ochobitshacenunbyte.com/2018/12/03/como-instalar-y-usar-snmpwalk/

OWASP Foundation. (2014). *OWASP testing guide v4*. Recuperado de: https://owasp.org/www-project-web-security-testing-guide/assets/archive/OWASP_Testing_Guide_v4.pdf

Paessler. (s.f.). *¿Qué es una cadena de comunidad SNMP?*. Recuperado de: https://www.paessler.com/es/it-explained/what-is-an-snmp-community-string

Rapid7. (2016, enero 27). *Simple Network Management Protocol (SNMP) best practices. The Rapid7 Blog*. Recuperado de: https://www.rapid7.com/blog/post/2016/01/27/simple-network-management-protocol-snmp-best-practices/

Stouffer, K., Pillitteri, V., Lightman, S., Abrams, M., & Hahn, A. (2015). *Guide to industrial control systems (ICS) security*. Recuperado de: https://doi.org/10.6028/NIST.SP.800-82r2

Teslag Training. (2021, 7 de junio). *Configuración SNMP. YouTube*. Recuperado de: https://www.youtube.com/watch?v=zpUke9RAK3U

Wikipedia. (s.f.). *Protocolo Simple de Red*. Recuperado de: https://es.wikipedia.org/wiki/Protocolo_simple_de_administraci%C3%B3n_de_red